

ACTIVIDAD 01 - ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

HACKER WOMEN COUNCIL - ETHICAL HACKER

NOMBRE: MARÍA TERESA MEDINA

FECHA: 31/08/2026



1. OBJETIVOS

①

ENCONTRAR VULNERABILIDADES O PROBLEMAS DE CONFIGURACIÓN DENTRO DE LA APLICACIÓN QUE PUDIERAN ESTAR COMPROMETIENDO LA SEGURIDAD DE DATOS DE LOS CLIENTES

②

CONOCER QUE TAN EXPUESTA ESTÁ LA APLICACIÓN Y QUE TAN LEJOS PODRÍA LLEGAR UN ATACANTE CON LA INFORMACIÓN DISPONIBLE

③

SABER SI ES POSIBLE QUE UN USUARIO NORMAL PUEDA ESCALAR PRIVILEGIOS Y ACCEDER A FUNCIONES ADMINISTRATIVAS



2. ALCANCE

SI SE EVALUARÁ

- APLICACIÓN WEB
- BASE DE DATOS
- MECANISMOS DE AUTENTICACIÓN

FUERA DE ALCANCE

- REDES SOCIALES DE LA EMPRESA
- EQUIPOS DE EMPLEADOS
- CUENTAS DE CORREO
- PROVEEDORES EXTERNOS
- OTROS SISTEMAS



3. AUTORIZACIÓN Y CONDICIONES

PERMISOS REQUERIDOS

- CREDENCIALES DE ACCESO
- HORARIOS DE LAS PRUEBAS

CONDICIONES ACORDADAS

- LAS PRUEBAS DEBEN REALIZARSE EN LOS HORARIOS DE MENOR ACTIVIDAD
- NO ESTÁ PERMITIDO REALIZAR ACCIONES QUE PUEDAN INTERRUPTIR EL FUNCIONAMIENTO DE LA PLATAFORMA
- NO ESTÁ PERMITIDO REALIZAR ACCIONES QUE AFECTEN LA INFORMACIÓN REAL DE LOS CLIENTES

4. TIPO DE PENTEST

GRAY-BOX



JUSTIFICACIÓN

INFORMACIÓN PARCIAL DE LA INFRAESTRUCTURA:

- * APLICACIÓN WEB
- * BASE DE DATOS
- * MECANISMOS DE AUTENTICACIÓN



5. PLANIFICACIÓN

OBJETIVOS

INVESTIGAR SI EL REPORTE DEL USUARIO SE TRATA DE UN ERROR DE CONFIGURACIÓN O UNA VULNERABILIDAD DE SEGURIDAD

ALCANCE

HACER TODAS LAS PRUEBAS SIN MODIFICAR, ELIMINAR O CORROMPER DATOS DE USUARIOS REALES Y MANTENER LA INVESTIGACION SOBRE LA EMPRESA LIMITADA A FUENTES ABIERTAS

PERMISOS Y CONDICIONES

PEDIR CREDENCIALES DE USUARIO PARA LAS PRUEBAS, FIRMAR ACUERDOS LEGALES Y HACER TODAS LAS PRUEBAS SIN INTERRUMPIR EL SERVICIO. Y DEJAR POR FUERA OTROS SISTEMAS, CORREOS DE LA EMPRESA, CORREOS DE EMPLEADOS Y PROVEEDORES

METODOLOGIA A UTILIZAR

OWASP

RECOPILACION DE INFORMACION PREVIA

TODA LA INFORMACION SOBRE LA EMPRESA Y EMPLEADOS SE HARA A TRAVES DE HERRAMIENTAS DE FUENTES ABIERTAS Y A TRAVES DE MOTORES DE BUSQUEDA CON GOOGLE DORKS

RECURSOS NECESARIOS

OWASP WEB APPLICATION SECURITY TESTING

https://github.com/OWASP/wstg/tree/master/document/4-Web_Application_Security_Testing

PROGRAMACION DEL PENTEST

LAS PRUEBAS SE EJECUTARAN DURANTE LAS HORAS DE MENOR TRAFICO DE USUARIOS **00:00 A 05:00 HORA LOCAL.**



6.FASES DEL PENTEST

RECONOCIMIENTO

A TRAVES DE MOTORES DE BUSQUEDA, UTILIZANDO GOOGLE DORKS PARA IDENTIFICAR ARCHIVOS O PANELES DE ADMINISTRACIÓN EXPUESTOS CON INFORMACIÓN SENSIBLE: **SITE:**

AURORAMARKET.COM INURL:ADMIN / SITE:

AURORAMARKET.COM FILETYPE:TXT, DOC, XLS...

Y ANALIZAR LOS METADATOS DE ESOS ARCHIVOS CON **EXIFTOOL** EN BUSQUEDA DE NOMBRES DE EMPLEADOS, HISTORIAL DE REVISIONES Y RUTAS DE ARCHIVOS QUE UN ATACANTE PUDIERA USAR POSTERIORMENTE PARA **ATAQUES DIRIGIDOS DE PHISHING**

A TRAVES DE HERRAMIENTAS DE **OSINT** SE BUSCARÁ INFORMACIÓN DE LA EMPRESA A TRAVES DE EMPLEADOS, YA QUE LA MAYORÍA DEL TIEMPO **LOS ERRORES DE CONFIGURACIÓN Y LA INFORMACIÓN PÚBLICA QUE LA EMPRESA NO DESCONOCE CONSTITUYEN EL PRIMER PUNTO DE ENTRADA PARA ATACANTES EXTERNOS.**

SE REALIZARÁ UN ESCANEEO DE PUERTOS E INSPECCIÓN DE CABECERAS HTTP CON **NMAP** Y **CURL** PARA CONOCER LA VERSIÓN DEL SERVIDOR, QUÉ PUERTOS PUDIERAN ESTAR ABIERTOS O MAL CONFIGURADOS Y RESPUESTAS QUE DETALLEN LA ARQUITECTURA INTERNA PARA DISMINUIR EL VECTOR DE ENTRADA DE UN ATACANTE

SE HARÁ INSPECCIÓN DEL CÓDIGO FUENTE DEL LADO DEL CLIENTE (HTML, JAVASCRIPT, CSS) DESDE EL **NAVEGADOR** Y ANALIZANDO EL TRAFICO GENERADO AL NAVEGAR POR EL SITIO WEB CON **OWASP ZAP** EN BUSQUEDA DE COMENTARIOS EN EL CODIGO, CLAVES API O CUALQUIER INFORMACION QUE PUDIERA SERVIR COMO VECTOR DE ENTRADA

ANALISIS DE VULNERABILIDADES

SEGUN LA INFORMACIÓN RECOPIADA, COMO LA VERSION DEL SERVIDOR, O LOS SERVICIOS EXPUESTOS, SE BUSCARAN LAS VULNERABILIDADES CONOCIDAS (CVE) PARA COMPROBAR SI LOS SERVICIOS SON VULNERABLES A EXPLOITS PÚBLICOS

EXPLOTACIÓN

CON BURPSUITE SE BUSCARÁN Y EXPLOTARAN VULNERABILIDADES DE CONTROL DE ACCESO Y TAMBIÉN SE HARÁN PRUEBAS DE INYECCIÓN SQL PARA ENCONTRAR DE DONDE VIENE LA FALLA REPORTADA POR EL USUARIO

POST EXPLOTACIÓN

SE BUSCARÁ SI ES POSIBLE ESCALAR PRIVILEGIOS DESDE UNA CUENTA DE USUARIO COMÚN, SUBIR UN ARCHIVO MALICIOSO MEDIANTE UN FORMULARIO DE SUBIDA DE ARCHIVOS QUE NOS PERMITA OBTENER UNA CONSOLA DE COMANDOS EN EL SERVIDOR (**WEBSHELL**) O PIVOTEAR DESDE LA BASE DE DATOS.

INFORME

SE HARÁ UN RESUMEN EJECUTIVO CON EL ALCANCE DE LAS PRUEBAS Y EVALUACIÓN GENERAL DE LOS RIESGOS CON UN TOP 3-5 DE VULNERABILIDADES CRÍTICAS Y DESCRIPCIÓN BREVE DE LOS HALLAZGOS QUE REPRESENTEN UN IMPACTO FINANCIERO, OPERATIVO O REPUTACIONAL DIRECTO A LA EMPRESA.

PARA LA METODOLOGÍA Y COBERTURA DE PRUEBAS SE UTILIZARÁ EL FORMATO DE OWASP (OWASP WSTG V4.2 / V5), INDICANDO QUÉ CATEGORÍAS FUERON EVALUADAS

Y UN INFORME TÉCNICO CON CADA VULNERABILIDAD IDENTIFICADA, CLASIFICACIÓN DEL RIESGO (VECTOR CVSS), DESCRIPCIÓN TÉCNICA Y RECOMENDACIÓN DE REMEDIACIÓN



7. INVESTIGACIÓN

METODOLOGÍA ELEGIDA

OWASP

POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

PORQUE PROPORCIONA TODO EL ESQUEMA PARA REALIZAR LAS PRUEBAS DE PENETRACIÓN A LA APLICACION WEB DESPUES DE HABER SIDO IMPLEMENTADA Y GARANTIZAR QUE NO SE HAYA PASADO NADA POR ALTO